

Payroll Shield Penetration Test

Problem Statement

The HR department stores employee salaries in the application.

Your ethical hacking team must evaluate whether confidential salary information can be disclosed.

- Identify weak authentication or encryption.
- Demonstrate possible information leakage.
- Suggest mitigation techniques.

CHALLENGE-4

1. Introduction

- The HR department uses an application to store confidential employee salary information.

- Since salary details are sensitive personal and organizational information, the application must provide strong confidentiality and access control.
- The objective of this ethical security assessment is to identify weak authentication or encryption, demonstrate possible information leakage using only the authorized test environment, and recommend suitable mitigation techniques.

2. Weak Authentication

Vulnerability 1: Weak Authentication

- The application may use weak passwords or insufficient login protection.
- **Risk:**
An unauthorized user could potentially gain access to the HR application and view confidential salary records.
- **Possible weaknesses**
 - Weak passwords
 - No account lockout or rate limiting
 - Poor session management
 - No additional protection for administrator accounts
- **Impact:**
Unauthorized users may access employee salary information.

3. Weak Encryption

Vulnerability 2: Plaintext Salary Storage

- If salary information is stored directly in a text file or database without encryption, anyone who obtains access to the storage may be able to read it.
- **Example:**

- Employee ID: E101
Employee Name: Rahul
Salary: 50000
- The salary is clearly visible, which creates a confidentiality risk.

Vulnerability 3: Weak Encryption Key Management

Even when encryption is implemented, security can be weakened if encryption keys are:

- Hard-coded in the application
- Stored together with encrypted data
- Easily accessible to unauthorized users
- Shared among multiple users

4. Possible Information Leakage

The demonstration should be performed only with dummy employee data in the authorized test environment.

Test 1 – Check Storage

1. Create a dummy employee record.
2. Enter a test salary.
3. Save the record.
4. Examine the application's test storage.
5. Check whether the salary is readable directly.

Vulnerable Result

- Test Employee: Rahul
Test Salary: 50000

Stored Data:
Employee ID: E101
Employee Name: Rahul
Salary: 50000

- **Finding:**
The salary is stored in plaintext, so an attacker who obtains unauthorized access to the storage could potentially read the salary information.

Test 2 – Authentication Check

Using only authorized test accounts:

1. Verify that authentication is required.
2. Test an invalid test credential.
3. Confirm that unauthorized access is rejected.
4. Check whether repeated failed attempts are properly restricted.

If unauthorized access is allowed, the application has an authentication weakness.

5. Attack Scenario

A possible attack scenario is:

Unauthorized User
↓
Weak Authentication
↓
Access to HR Application
↓
Employee Salary Records
↓
Confidential Salary Information Disclosed

Alternatively:

Unauthorized Storage Access
↓
Salary Database/File
↓
Plaintext Salary Data
↓
Information Leakage

6. Mitigation Techniques

1. Implement Strong Authentication

Use:

- Strong password policies
- Secure password hashing
- Multi-factor authentication for HR administrators
- Login rate limiting
- Account lockout or temporary delays after repeated failures

2. Encrypt Salary Information

- Sensitive salary information should be encrypted before storage.
- For real applications, use a modern authenticated encryption method such as **AES-GCM**.

Employee Salary



Encryption



Encrypted Database

3. Secure Encryption Keys

- Encryption keys should not be hard-coded into source code.
- Keys should be stored using a secure key-management mechanism and access should be restricted.

4. Implement Role-Based Access Control

- Only authorized HR personnel should access salary information.
- HR Administrator → Salary Access ✓
HR Staff → Required Access ✓

Other Employee → Salary Access X
Unauthorized User → Access Denied X

5. Protect Backups

- Employee salary backups should also be encrypted because attackers may target backup files.

6. Restrict Database Permissions

- Only authorized application services and administrators should have access to the salary database.

7. Maintain Audit Logs

The application should record:

- Login attempts
- Successful authentication
- Failed authentication
- Salary-record access
- Unauthorized access attempts

This helps detect and investigate suspicious activity.

7. Security Comparison

Area	Weak Implementation	Secure Implementation
Authentication	Weak password	Strong authentication
Salary Storage	Plaintext	Encrypted
Encryption	Weak/missing	AES-GCM or equivalent
Key Management	Hard-coded keys	Secure key management
Access Control	Everyone can access	Role-Based Access Control
Backup	Unencrypted	Encrypted

Monitoring	No logs	Security audit logs
------------	---------	---------------------

8. Conclusion

- The security assessment shows that employee salary information can be exposed through weak authentication, plaintext storage, weak encryption, and poor key management.
- The information leakage should be demonstrated only using dummy data in the authorized test environment. Implementing strong authentication, AES-GCM encryption, secure key management, role-based access control, encrypted backups, restricted database permissions, and audit logging can significantly reduce the risk of unauthorized disclosure of employee salary information.